Registro de Actividades de Tratamiento (RAT)

Inventario de qué datos personales trata el sistema, con qué finalidad, bajo qué base legal, quién accede y por cuánto tiempo se conservan. Documento exigido por la Ley 21.719 (y consistente con las obligaciones de custodia de la Ley 20.584 y de seguridad de la Ley 19.628). Corresponde al issue #29 (T6.3), parte del plan de compliance derivado de la auditoría técnica y legal (14 jul 2026).

Este documento se deriva directamente del modelo de datos real (`backend/prisma/schema.prisma`) y de las decisiones ya implementadas en el código (versionado de consultas, ledger de consentimientos, bitácora de auditoría). Debe actualizarse cada vez que se agregue un modelo o un campo que trate datos personales.

Última revisión: 2026-10-13 (sincronización con el código y con `schema.prisma` : se corrigieron o ampliaron las filas 4, 5, 7 y 10 a 14, se agregaron las filas 26 a 28 y la sección "Cifrado y medidas técnicas", y se completó la sección de transferencia internacional con los hechos de Vercel, Cloudflare y Google Fonts; antes, el mismo 2026-10-13, se agregaron las filas 23 a 25 del informe de alta, ADR 0006; el 2026-10-08 se agregaron las filas 21 y 22 del bloque de pacientes menores, ADR 0007; sección "Responsable del tratamiento" reescrita por el issue #376; el resto se sincronizó con el código y con `schema.prisma` el 2026-10-06).

Responsable del tratamiento

"Umbral - RCE" es el nombre del producto (sistema de gestión de fichas clínicas descrito en este repositorio), no una persona jurídica. Los roles se distinguen según el tipo de dato (issue #376):

Datos	Responsable del tratamiento	Encargado del tratamiento
Pacientes y su ficha clínica (filas 1-3, 5-8, 12-14)	El terapeuta tratante, que presta la atención y es el obligado por la Ley 20.584	Ground Zero Devs, operador de Umbral, que procesa los datos por cuenta del terapeuta
Cuenta y uso de la plataforma por el propio profesional (filas 4, 4b, 15-17, 19-20)	Ground Zero Devs, operador de Umbral	Los procesadores de la tabla "Transferencia internacional de datos"

Las filas 9-11 y 18 mezclan ambos roles: el contenido es del terapeuta y la infraestructura es del operador. Clasificación (issue #414):

Fila	Actividad	Responsable	Encargado	Criterio
9	Archivos personales	El terapeuta, dueño del material	Ground Zero Devs, que lo almacena	El contenido es de la práctica del profesional. Si sube un archivo con datos de pacientes, se rige como la fila 5
10	Backups	Ground Zero Devs, para los datos de cuenta	Ground Zero Devs, para los datos de pacientes que contiene el volcado (el terapeuta sigue siendo su responsable)	El volcado incluye ambos tipos de dato y lo decide el operador como medida de seguridad

Fila	Actividad	Responsable	Encargado	Criterio
11	Sincronización con Google Calendar	El terapeuta, que decide conectar su agenda y cuyos pacientes aparecen como iniciales	Ground Zero Devs. Google LLC actúa como subencargado	El token OAuth es dato de cuenta del terapeuta y lo custodia Ground Zero Devs
18	Bloques ocupados del calendario	El terapeuta, dueño de su agenda	Ground Zero Devs	Son intervalos de tiempo del propio profesional, sin datos de pacientes

Estado: roles definidos para el issue #376 y alineados con la política pública (repo `umbral-landing`, página `/privacidad-general`). El abogado del proyecto los revisó y los dio por correctos el 2026-10-08, incluida la clasificación de las filas 9-11 y 18 (issue #414), según informó el responsable del proyecto; no hay un documento de esa revisión en el repositorio. Cualquier ajuste posterior se hará cuando el abogado lo indique. Los DPA de Render y Sentry están en `docs/evidencia-compliance/`.

Inventario de actividades de tratamiento

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
1	Ficha clínica	`Patient`	Identificación, RUT, contacto, contacto de emergencia, médico/psiquiatra tratante	Prestación del servicio psicológico	Consentimiento informado, purpose `TREATMENT` en `PatientConsent`	Terapeuta tratante (`therapistId`); único rol del sistema (`enum Role { PROFESSIONAL }`), sin ruta de acceso excepcional	15 años desde el cierre (Ley 20.584). Soft delete (`deletedAt`), nunca se borra físicamente
2	Consulta clínica	`Consultation` + `ConsultationHistory`	Motivo de consulta, intervención, acuerdos, próxima sesión	Registro obligatorio de cada sesión	Consentimiento `TREATMENT`; versionado append-only (`groupId`, `correctsId`)	Terapeuta tratante; correcciones quedan en `ConsultationHistory`	Igual que ficha (15 años); ninguna versión se sobreescribe
3	Telemedicina	`Consultation.sessionType = TELEMED`, `PatientDocument.type = TELEMED_AGREEMENT`	Datos de la consulta + acuerdo de telemedicina firmado	Atención remota	Consentimiento específico, purpose `TELEMEDICINE`	Terapeuta tratante	Igual que ficha

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
4	Email transaccional de cuenta (verificación de cuenta, restablecimiento de contraseña, cambio de email y aviso de recuperación de MFA)	`MailService` vía Resend (`backend/src/modules/mail/mail.service.ts`)	Nombre y email del profesional (dato del usuario del sistema, no del paciente); en el cambio de email, también la casilla nueva	Verificar la cuenta, permitir recuperar el acceso y avisar de cambios sensibles de la cuenta (cambio de email y recuperación de MFA)	Necesidad contractual para operar la cuenta; no requiere consentimiento del paciente porque no trata sus datos	Resend (procesador, EE.UU.); nadie más: el link de verificación/reset no viaja a ningún otro tercero	El email en sí no se retiene por Umbral más allá del envío; el token asociado expira (30 min en el reset)
4b	Control de alta de cuenta (código de invitación)	`InvitationCode` (`backend/src/modules/auth/`)	Código de un solo uso + `createdById` / `usedById` (referencias al propio `User`, ya cubierto por la fila 4); sin datos personales nuevos	Impedir que cualquiera con el link público se cree una cuenta de terapeuta sin control (issue #124)	Necesidad contractual para operar la cuenta, igual base que la fila 4; no trata datos del paciente	El único email autorizado en `INVITE_CREATOR_EMAIL` (genera); el propio profesional que se registra (consume)	El código expira a los 7 días; una vez usado o expirado no se borra el registro (queda como evidencia de qué invitación originó qué cuenta)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
5	Documentos adjuntos	`PatientDocument` (consentimiento informado, informes, otros)	Archivos vinculados al paciente (PDF, Word, Excel, ZIP e imágenes de hasta 25 MB), cifrados en la aplicación antes de subirse al bucket de Backblaze B2. Tipos (`DocumentType`): consentimiento informado, asentimiento informado, acuerdo de telemedicina, informe del paciente, resumen de sesión, resultado de examen, informe de alta, autorización de entrega y otros	Soporte de la ficha clínica	Consentimiento `TREATMENT`	Quien subió (`uploadedBy`) + terapeuta tratante	Igual que ficha. Un documento subido por error no se elimina: se anula con motivo obligatorio (`voidedAt`, `voidedById`, `voidReason`), sigue listado y descargable por custodia, y la anulación queda auditada como `DOCUMENT_VOID`. Si el documento sustentaba el consentimiento vigente y no queda otro del mismo tipo, se agrega un evento `REVOKE` al ledger `PatientConsent` (nunca se modifica ni borra un evento previo)
6	Exportación de PDF de ficha	Servicio de reportes (acción `EXPORT_PDF` en `AuditLog`)	Ficha + historial clínico completo	Entrega al paciente o a fiscalización	Deriva del consentimiento `TREATMENT` ya otorgado	Quien exporta, queda auditado	Hereda la retención de 15 años (obligación de custodia impresa en el pie del PDF)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
7	Bitácora de auditoría	`AuditLog`	Usuario (`userId` , nulo en los intentos sin sesión), acción (`AuditAction`), recurso, id del recurso, IP, user agent y detalle (método y URL de la petición, y el `patientId` cuando aplica)	Trazabilidad y evidencia ante fiscalización	Obligación legal / interés legítimo; no requiere consentimiento del paciente	Inserción automática por el sistema: un interceptor global registra cada petición autenticada (GET como `VIEW` , POST como `CREATE` , PATCH como `UPDATE` , DELETE como `SOFT_DELETE` ; las descargas de documentos, archivos personales e informes de alta quedan como `VIEW` con detalle `download` , y la exportación de PDF y la anulación de documentos tienen acciones propias, `EXPORT_PDF` y `DOCUMENT_VOID`). Los servicios agregan los eventos de cuenta (login, MFA, contraseña, cambio de email, conexión de Google Calendar y de pagos) y los del informe de alta. Un 403 o 404 sobre un recurso clínico queda como `UNAUTHORIZ`	**15 años**, igual que la ficha que audita: el log solo tiene razón de ser mientras existe el dato que audita. No hay purga automática de `AuditLog` en el código

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
						`ED_ATTEMPT`, con un tope por IP (10 por minuto por defecto). No existe pantalla ni endpoint para consultar la bitácora: el profesional solo ve sus últimos 20 eventos de MFA (`GET /profile/mfa-history`). Tabla append-only: trigger en la base y rol de ejecución de la aplicación sin permisos de modificación (`docs/incident-log.md`)	
8	Historial de cambios de ficha	`PatientHistory` (snapshot + diff)	Ficha completa antes/después de cada edición	Trazabilidad de modificaciones a datos clínicos	Deriva de `TREATMENT`	Quien edita (`changedBy`), auditoría	Igual que ficha

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
9	Archivos personales (biblioteca privada por usuario)	`SharedFile`	Plantillas, formularios, protocolos, libros: material de la propia práctica del profesional, no datos de pacientes. El nombre del modelo viene de una versión multi-profesional anterior; hoy `SharedFilesService` filtra por `uploadedById`, así que nada se comparte entre cuentas (comentario en `schema.prisma`)	Recursos de trabajo del propio profesional	No aplica (no es dato personal de paciente), salvo que el profesional suba por su cuenta un archivo con datos personales	Solo el profesional que subió el archivo	Sin retención legal específica: se conserva hasta que el profesional lo elimine

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
10	Backups	Workflow `.github/workflows/backup.yml` (fuera de Prisma; reemplaza a `backups/backup.sh`, pensado para una VM propia que ya no existe; `backup.sh` fue retirado en el issue #61)	Volcado diario (cron `0 5 * * *`, 05:00 UTC; `pg_dump` con Postgres 17) cifrado con `openssl enc -aes-256-cbc -pbkdf2` de toda la base, incluidas las columnas ya cifradas por la aplicación	Continuidad operativa / recuperación ante desastre	Obligación de seguridad (Ley 19.628 art. 11 bis)	Quien tenga las credenciales de Backblaze B2 y la frase de cifrado (gestor de contraseñas del terapeuta)	Sin rotación: se conserva **todo, indefinidamente**; a este volumen (~40 KB/backup diario) 15 años de historial completo ocupan ~230 MB, muy por debajo de los 10 GB gratis de B2, así que no hace falta distinguir "operativo" de "custodia legal" con políticas de borrado distintas (issue #8, cerrado 2026-08-03)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
11	Sincronización con Google Calendar (opcional, por terapeuta)	`GoogleCalendarConnection`, `CalendarEventLink` (`backend/src/modules/calendar-integration/`)	Iniciales del paciente + código corto no reversible (`sha256` truncado sobre `patient.id`, sin clave), fecha/hora de la sesión, link de vuelta a Umbral. Nunca RUT, nombre completo, `sessionType` ni texto clínico. El refresh token OAuth del terapeuta se cifra AES-256-GCM (`GOOGLE_TOKEN_ENCRYPTION_KEY`, dedicada, no comparte clave con `DocumentEncryptionService`; ver la sección "Cifrado y medidas técnicas"). La conexión guarda además el email de la cuenta de Google (`googleAccountEmail`), el `calendarId`, el scope y el estado de sincronización	Que el terapeuta vea sus sesiones de Umbral en su propia agenda de Google, sin re-tipearlas	No es un dato del paciente identificable fuera de Umbral (contenido minimizado por diseño); el terapeuta conecta voluntariamente su propia cuenta de Google (`calendar.events`, `access_type=offline`); **pendiente de revisión legal** si la base habilitante es la necesidad contractual de operar la cuenta del terapeuta (mismo criterio que el email transaccional de la fila 4) o si, por derivarse de metadata de una sesión clínica, requiere la misma base que las filas 1-9 (ver sección "Transferencia internacional de datos")	El terapeuta dueño de la conexión (su propio Google Calendar); Google LLC como procesador de los eventos minimizados	Mientras la conexión esté `CONNECTED`; el evento y el mapeo (`CalendarEventLink`) se borran al eliminar la sesión/paciente o al desconectar; una revocación (`invalid_grant`) marca la conexión `DISCONNECTED` y detiene el envío sin reintentos

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
12	Recordatorios de sesión	`Notification`, `ReminderDispatch` (`backend/src/modules/reminders/`, `backend/src/modules/notifications/`)	Nombre del paciente + fecha/hora de la sesión, en el cuerpo del recordatorio (canal `IN_APP` y `EMAIL`, a lo más un envío por `(groupId, sessionDate, offsetKind, channel)`), con avisos 24 h y 2 h antes de la sesión (`H24`, `H2`), revisión cada 5 minutos y reintentos acotados (`REMINDER_MAX_ATTEMPTS`). El modelo `Notification` guarda también otros avisos al terapeuta: Google Calendar desconectado, cobro vencido (con el nombre del paciente en el cuerpo), anomalía de cobro y paciente autoagendado sin monto de sesión	Recordarle al terapeuta sus próximas sesiones	Deriva del consentimiento `TREATMENT` ya otorgado: mismo dato de la ficha, en un canal adicional; el email vía Resend llega a la casilla del propio terapeuta, no del paciente (mismo criterio que la fila 4)	El terapeuta destinatario; Resend como procesador del canal email (misma evidencia que la fila 4)	`ReminderDispatch` no se borra (la unicidad evita reenvíos duplicados). La `Notification` in-app leída se purga diariamente a las 04:30 pasados 30 días (`NotificationsPurgeService`, `NOTIFICATIONS_PURGE_ENABLED`, `NOTIFICATIONS_PURGE_RETENTION_DAYS`); las no leídas no se purgan

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
13	Cobro en línea por sesión (opcional, por terapeuta)	`Payment`, `PaymentAccount` (`backend/src/modules/payments/`)	Nombre del paciente + email (para el link de pago y el aviso de cobro vencido), monto y fecha de la sesión (`amount`, `dueDate`), estado del cobro (`PENDING`, `PAID`, `LATE`, `CANCELLED`), token y URL de pago de Flow (`gatewayToken`, `paymentUrl`) y marcas de envío del link y del aviso de cobro vencido. Del terapeuta: credenciales de su propia cuenta Flow (apiKey/secretKey, `PaymentAccount.credentialEncrypted`), cifradas en reposo bajo `PAYMENT_CREDENTIALS_ENCRYPTION_KEY`, dedicada, mismo criterio que `GOOGLE_TOKEN_ENCRYPTION_KEY` / `DOCUMENT_ENCRYPTION_KEY` (sdd/payments-	Cobrar automáticamente cada sesión al paciente, liquidando directo a la cuenta del terapeuta que la dictó	Necesidad contractual de operar el cobro de la sesión; el terapeuta conecta voluntariamente su propia cuenta de Flow; **pendiente de revisión legal** si el envío del email con el link de pago (`MailService.sendPaymentLinkEmail`) requiere su propia finalidad de consentimiento (`ConsentPurpose`) distinta de `TREATMENT`, dado que hoy no existe ese member en el schema (ver design.md, Open Questions)	El terapeuta dueño del cargo (su propia cuenta de Flow); Flow S.A. como procesador del checkout y la liquidación	Mientras el cargo exista (`Payment`, mismo ciclo de vida que la sesión que factura, ligado por `groupId`, nunca se borra al pagarse); la cuenta de pagos (`PaymentAccount`) persiste hasta que el terapeuta la desconecte

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
			multigateway-redesign: cada terapeuta conecta su propia cuenta, ya no hay comercio integrador de Umbral). Nunca datos de tarjeta ni credenciales bancarias: el checkout hospedado corre íntegramente en Flow, Umbral nunca custodia el dinero ni ve el medio de pago				

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
14	Auto-agenda pública de pacientes (sdd/patient-self-scheduling)	`TherapistAvailability`, `AvailabilityBlockout`, `PublicHoliday`, `BookedSlot` (infraestructura de horario/cupo; dato operativo del propio terapeuta, no dato personal de paciente, mismo criterio que la fila 9). Adicionalmente, `Patient`: la reserva pública **crea o vincula** un registro de esta tabla, que es donde entra el dato personal (mismas filas que la fila 1)	Dos flujos distintos: (a) la configuración del propio horario del terapeuta (día/hora, bloqueos, duración de sesión); no es dato personal de un paciente; (b) para un paciente **nuevo** creado vía el formulario público: nombre completo, RUT, fecha de nacimiento y email (obligatorio para un adulto) y, opcionalmente, ocupación, dirección, teléfono, contacto de emergencia y médico o psiquiatra tratante; si el paciente es menor de edad, también los datos de un representante legal (fila 21); y el origen de la visita (`acquisitionSource` y `acquisitionReferrer`: `utm_source`, dominio o URL del referrer). Se recolectan **sin**	Permitir que el paciente reserve su propia sesión sin intervención manual del terapeuta	**Pendiente de revisión legal.** Un paciente autocreado por este flujo público no ha pasado por la misma captura de consentimiento informado que la fila 1; no está resuelto si corresponde que herede automáticamente el consentimiento `TREATMENT` (y en qué momento se entendería otorgado), si debe capturarse un consentimiento propio en el formulario público antes de crear la ficha, o si el terapeuta debe regularizarlo manualmente después. Este documento no toma posición sobre cuál de esas opciones es la correcta; solo deja constancia de que hoy no se captura consentimiento explícito en el formulario público	El terapeuta dueño del link (mismo que fila 1); el paciente que se autoagenda ingresa sus propios datos pero no tiene ninguna sesión ni cuenta en el sistema (sin autenticación, sin OTP)	Igual que la ficha (fila 1) una vez creado el `Patient`: 15 años, mismo criterio (Ley 20.584)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
			verificación de identidad manual por el terapeuta y **sin pasar por el flujo de consentimiento informado** (`PatientConsent` , purpose `TREATMENT`) que sí atraviesa un paciente creado por un terapeuta autenticado hoy. Esta diferencia es la brecha legalmente relevante de esta fila				

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
15	Perfil público del terapeuta (público por diseño)	Campos `name`, `bio`, `specialty`, `website`, `slug` y avatar del modelo `User`, servidos por `GET /public/therapists/:therapistId/profile` (sin autenticación)	Nombre, bio corta, especialidad, sitio web opcional (URL `http`/`https`), foto de perfil y `slug` (identificador público derivado del nombre, que arma el link `/book/<slug>`; se regenera al cambiar el nombre) del propio terapeuta. No incluye email, teléfono ni identificadores internos; el sitio web es el canal de contacto que el terapeuta decide publicar. Ningún dato de pacientes	Que el paciente conozca al terapeuta y tenga un canal de contacto antes de reservar en su agenda pública	El terapeuta carga cada campo voluntariamente desde "Perfil" sabiendo que es público; todos son opcionales y se pueden vaciar (el sitio web con cadena vacía)	Cualquier persona con el link de agenda pública (público por diseño); no hay procesador adicional	Mientras el campo esté cargado; el terapeuta puede borrarlo en cualquier momento y deja de publicarse al instante
16	Sesiones de login	`Session` (`backend/src/modules/auth/`)	`jti` del token, usuario, fechas de creación/expiración/revocación, `ipAddress` y `userAgent` del dispositivo desde el que se inició sesión. Es dato del profesional, no del paciente	Poder revocar sesiones (`POST /auth/logout`, `/auth/logout-all`, cambio de contraseña) y rechazar tokens robados o vencidos	Necesidad contractual y obligación de seguridad (Ley 19.628 art. 11 bis) para operar la cuenta; no trata datos del paciente	El propio sistema (`JwtStrategy` valida cada request); no hay pantalla que liste las sesiones	Purga diaria a las 04:00 (`SessionPurgeService`, `SESSION_PURGE_ENABLED`) de las sesiones expiradas o revocadas hace más de 7 días

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
17	Segundo factor (MFA)	`User.mfaSecret`, `User.lastUsedStep`, `MfaRecoveryCode`	Secreto TOTP del profesional, cifrado en reposo con AES-256-GCM bajo `MFA_SECRET_ENCRYPTION_KEY` (clave dedicada, distinta de las de documentos, Google y pagos); último paso TOTP usado (anti-reutilización); 10 códigos de recuperación almacenados solo como hash (`codeHash`) con marca de uso (`usedAt`). Dato del profesional, no del paciente	Autenticación reforzada obligatoria y recuperación de la cuenta sin intervención manual	Obligación de seguridad (Ley 19.628 art. 11 bis) y necesidad contractual para operar la cuenta	Solo el propio sistema; los códigos de recuperación no se pueden volver a ver después de mostrarse	Mientras exista la cuenta; al regenerar los códigos de recuperación, los anteriores se reemplazan
18	Bloques ocupados del calendario de Google (opcional, solo si `CALENDAR_AVAILABILITY_OVERLAY_ENABLED=true`)	`CalendarBusyBlock` (`backend/src/modules/calendar-integration/calendar-busy.service.ts`)	Solo intervalos de tiempo (`startsAt`, `endsAt`) de los eventos ocupados del Google Calendar que el terapeuta ya conectó (fila 11). No se guardan títulos, descripciones, asistentes ni identificadores de eventos	Descontar esos horarios de la disponibilidad que ve el paciente en la agenda pública	Mismo criterio que la fila 11: el terapeuta conecta voluntariamente su cuenta de Google; **pendiente de revisión legal** junto con ella	El terapeuta dueño y el cálculo de disponibilidad; el paciente solo ve el horario resultante como libre u ocupado, sin detalle	Se reemplazan en cada sincronización (cron cada 30 minutos)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
19	Seguimiento de entrega y apertura de recordatorios por email	`ReminderDispatch` (`resendMessageId`, `deliveredAt`, `openedAt`) alimentado por `POST /webhooks/resend` (`backend/src/modules/webhooks/`)	Identificador del mensaje en Resend y marcas de tiempo de entrega y apertura del email de recordatorio. El email va a la casilla del terapeuta (fila 12); el seguimiento de apertura lo aporta Resend	Que el terapeuta sepa si su recordatorio fue entregado o abierto (badge en la lista de consultas)	Mismo criterio que las filas 4 y 12: dato operativo del profesional, sin consentimiento adicional del paciente	El terapeuta (badge en Consultas); el webhook solo acepta eventos con firma Svix válida (`RESEND_WEBHOOK_SECRET`)	Igual que `ReminderDispatch` (fila 12): no se borra

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
20	Registro de errores (Sentry, opcional)	`backend/src/instrument.ts` y `frontend/src/utils/error-tracking.ts` (sin modelo Prisma)	Solo si se define `SENTRY_DSN` / `VITE_SENTRY_DSN`. Errores 500 y excepciones no controladas: tipo, mensaje y traza de la excepción. En el backend se redactan emails y RUT en mensajes y se descartan bodies, cookies, headers, query string y datos de breadcrumbs; en el frontend se descartan bodies, cookies y headers de la request (la redacción de emails y RUT del mensaje solo existe en el backend). `tracesSampleRate` en 0 (sin trazas de rendimiento)	Detectar y corregir fallas de producción	Interés legítimo en la seguridad y continuidad del servicio; el diseño busca que no viajen datos de pacientes, pero un mensaje de error podría incluir texto no previsto	El equipo de desarrollo con acceso al proyecto Sentry; Sentry como procesador (ver Transferencia internacional)	La define el plan del proyecto Sentry (por confirmar); Umbral no conserva copia propia

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
21	Representante legal de un paciente menor de 18 años (ADR 0007)	`LegalGuardian` (`backend/src/modules/patients/guardians.service.ts`); `PatientConsent.grantedBy` y `PatientConsent.guardianId`	Del representante (tercero, no es el paciente): nombre completo, RUT, relación con el paciente (madre, padre, tutor legal, curador, cuidador u otro), email, teléfono, marcas de rol (`isPayer`, `receivesCommunications`, `canAccessReports`, `canConsent`), tipo de custodia (`SOLE`, `SHARED`, `UNKNOWN`) y `hasConflict`. Hasta 2 por paciente. En `PatientConsent`, quién otorgó cada consentimiento (`PATIENT` o `GUARDIAN`) y qué representante	Autorizar el tratamiento de un menor, dirigirle a él los avisos y cobros de sesión (link de pago y aviso de pago atrasado) y la entrega del informe de alta (fila 24). Para las consultas, `assertTreatmentConsent` exige que el consentimiento de un menor lo haya otorgado un representante con `canConsent` desde `MINOR_GUARDIAN_ENFORCEMENT_DATE` (2026-12-01)	Consentimiento `TREATMENT` otorgado por el representante, que actúa por el menor (Ley 20.584 art. 14; Ley 21.719 art. 16 quáter de la Ley 19.628, sujeta a su entrada en vigencia). El representante cargado desde la agenda pública no pasa por una captura de consentimiento propia: el terapeuta registra el consentimiento después (ver pendientes). **Pendiente de revisión legal**	Terapeuta tratante. Los datos del representante salen hacia Resend (email de cobro y de aviso, fila 13) y hacia Flow (email del pagador); si ningún representante tiene email, no se emite la orden ante Flow y no se usa el email del terapeuta como pagador. El alta, la edición y la baja de un representante quedan en `AuditLog`	Igual que la ficha (15 años). Un representante que firmó un consentimiento no se puede eliminar (FK `RESTRICT`, el ledger es append-only); los demás se borran físicamente

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
22	Asentimiento del paciente menor de edad (ADR 0007)	`PatientAssent` (`backend/src/modules/patients/assents.service.ts`), `PatientDocument.type = INFORMED_ASSENT`	Tramo etario al registrar (`UNDER_14` o `AGE_14_17`, calculado por el servidor desde `birthDate`), acción (`GRANTED`, `REFUSED`, `WITHDRAWN`, `INFORMED_AND_HEARD`), nota breve opcional (hasta 500 caracteres; el formulario no debe incluir datos sensibles), documento de respaldo opcional y quién lo registró	Dejar constancia de que el niño, niña o adolescente fue informado y oído, y de su asentimiento o rechazo. Nunca reemplaza el consentimiento del representante; un rechazo alerta al terapeuta y no bloquea	Derecho del niño, niña o adolescente a ser informado y oído (Ley 21.331 art. 25; Ley 21.430). El diseño por tramos (informado y oído bajo 14 años, asentimiento expreso de 14 a 17) es una recomendación conservadora de producto, no una exigencia legal verificada. **Pendiente de revisión legal**	Terapeuta tratante	Igual que la ficha (15 años). Ledger append-only: no hay edición ni borrado de eventos

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
23	Cierre del tratamiento e informe de alta (ADR 0006)	`TreatmentDischarge` (`backend/src/modules/discharges/`); `Patient.treatmentStatus` ; `User.rut` y `User.professionalRegistration` (firmante); `PatientDocument.type = DISCHARGE_REPORT` ; `Consultation.cancelledAt` y `cancelledByDischargeId`	Del paciente: fechas de ingreso y de alta, número de sesiones, motivo de consulta, diagnóstico (opcional), resumen de evolución, estado al alta y recomendaciones; motivo de cierre (alta, derivación o deserción), motivo de deserción de una lista cerrada con una nota breve, y destino de la derivación. Del terapeuta firmante: nombre, RUT y registro profesional, congelados al emitir. Hash SHA-256 del contenido (`contentHash`) y de los bytes del PDF (`pdfSha256`). El PDF se guarda cifrado como documento de la ficha. Si el terapeuta sube su propio PDF (`source = UPLOADED`), el contenido vive en el archivo y los campos de	Dejar constancia del cierre del tratamiento (la epicrisis forma parte de la ficha clínica, Decreto 41 art. 6), cancelar las consultas futuras del paciente y permitir verificar que el informe no fue alterado desde su emisión	Consentimiento `TREATMENT` vigente, exigido al emitir (misma validación que las consultas). No hay norma verificada que obligue a un psicólogo independiente a emitir epicrisis ni que fije su formato. **Pendiente de revisión legal** (ADR 0006)	Terapeuta tratante (único rol). Para un menor, el PDF incluye los datos del representante con `canAccessReports` . La emisión, la corrección y el cierre quedan en `AuditLog` (`DISCHARGE_ISSUE` , `DISCHARGE_CORRECT` , `TREATMENT_CLOSED` , `CONSULTATION_CANCELLED`) y la descarga del PDF como lectura auditada	Igual que la ficha (15 años). Un informe emitido es inmutable: corregirlo crea una versión nueva y la anterior queda verificable y marcada como reemplazada; no se borra. Los textos del informe no tienen cifrado a nivel de columna todavía (seguimiento del ADR 0006)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
			texto quedan vacíos				

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
24	Entrega del informe de alta (ADR 0006)	`DischargeDelivery` (`discharge-deliveries.service.ts`); `PatientDocument.type = DELIVERY_AUTHORIZATION`	Tipo de destinatario (paciente, representante legal o tercero), nombre del destinatario (el del paciente o del representante se toma de la ficha; el del tercero lo escribe el terapeuta), finalidad (hasta 200 caracteres, sin datos clínicos), canal (en persona, email, correo postal u otro), fecha fijada por el servidor y quién la registró. Para un tercero, el documento de autorización cargado en la ficha (autorización del paciente o del representante, u oficio de un tribunal) y la declaración del terapeuta de que lo revisó (`authorizationAttested`)	Dejar constancia de a quién, cuándo, por qué canal y para qué se entregó el informe, y de la autorización que respaldaba la entrega a un tercero. El sistema no envía el informe: se descarga y se registra la entrega	Ley 20.584 art. 13: los terceros no relacionados con la atención no acceden a la ficha; la entrega procede a solicitud expresa del titular o su representante legal, de un tercero autorizado por el titular mediante poder simple ante notario, de los tribunales, o de fiscales y abogados con autorización del juez (entre otros). A un paciente menor de 18 años no se le entrega directamente: se entrega a su representante con `canAccessReports`. **Pendiente de revisión legal**: el sistema acepta cualquier documento cargado como autorización; no exige ni comprueba el poder simple ante notario, ni que el documento	Terapeuta tratante. La auditoría `DISCHARGE_DELIVER` no incluye nombres ni finalidad; esos datos quedan solo en `DischargeDelivery`. Las entregas son de solo agregar: no se editan ni se borran. Borrar a un representante con entregas registradas muestra un aviso	Igual que la ficha (15 años)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
					de un tribunal sea un oficio, ni la autorización del juez para fiscales y abogados; solo exige que el terapeuta declare haber revisado el documento		
25	Aviso de cancelación de consultas al cerrar el tratamiento (ADR 0006)	`DischargeCancellationNotifier`; `MailService.sendConsultationCancelledEmail`. No crea modelos	Email y nombre del destinatario, y fecha y hora (America/Santiago) de las consultas canceladas. No incluye el motivo del cierre, el diagnóstico ni el estado clínico	Avisar al paciente, o al representante de un menor, que sus consultas futuras quedaron canceladas	Base habilitante no definida: el correo no lleva datos clínicos. **Pendiente de revisión legal**, igual que el resto de los avisos por email (fila 13)	Adulto: su propio email. Menor: solo los representantes con `receivesCommunications` y email, nunca el email del menor. Sale hacia Resend (encargado de tratamiento; ver la sección de transferencia internacional). Si no hay destinatario o falla el envío, se omite y no interrumpe el cierre	No se guarda el contenido del correo. Resend conserva su propio registro de envíos según su política

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
26	Cuenta del profesional (registro e inicio de sesión)	`User` (`backend/src/modules/auth/` , `backend/src/modules/profile/`)	Email (normalizado a minúsculas), nombre, rol, hash Argon2 de la contraseña (`passwordHash`), estado de verificación del email, email pendiente de confirmar (`pendingEmail`), marcas de invalidación de tokens y de cambio de contraseña (`passwordResetTokenIssuedAt` , `passwordChangedAt` , `mustChangePassword`), indicador `mfaEnabled` (el secreto y los códigos de recuperación, en la fila 17), foto de perfil (`avatarMimeType` , `avatarUpdatedAt` ; el archivo vive en el bucket de avatares de Backblaze B2, sin cifrado a nivel de aplicación), duración de sesión (`sessionDurationMinutes`), datos del perfil público	Crear y operar la cuenta del profesional	Mismo criterio que la fila 4 (necesidad contractual para operar la cuenta); no trata datos del paciente	El propio profesional (`GET` y `PATCH /profile`); la contraseña solo existe como hash	Mientras exista la cuenta. Baja lógica (`deletedAt`); `AuditLog.userId` referencia al usuario con `onDelete: Restrict` , así que un usuario con eventos en la bitácora no se puede borrar físicamente

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
			(fila 15) y, opcionales, RUT y registro profesional para firmar informes de alta (fila 23; no se exponen en el perfil público ni en el login). Es dato del profesional, no del paciente				
27	Limitación de tasa y detección de abuso	Sin modelo Prisma: `@nestjs/throttler` (`backend/src/modules/auth/auth.module.ts`) y `UnauthorizedAttemptLimiter` (`backend/src/common/utils/unauthorized-attempt-limiter.util.ts`)	IP del cliente (resuelta con `TRUSTED_PROXY_HOPS` , 3 saltos: Render detrás de Cloudflare según `render.yaml`) o `userId` , como clave de los contadores en memoria del proceso. La IP también se guarda en `AuditLog` y en `Session` (filas 7 y 16)	Frenar fuerza bruta y abuso en las rutas de login, MFA, alta, recuperación de contraseña, cambio de email, perfil, agenda pública y pagos, y acotar el ruido en la bitácora	Obligación de seguridad (Ley 19.628 art. 11 bis), mismo criterio que la fila 16	Solo el propio sistema	Solo durante la ventana de cada límite; los contadores viven en memoria y se pierden al reiniciar el proceso

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
28	Sesión y marca de actividad en el navegador del profesional	`localStorage` del frontend (`frontend/src/context/AuthContext.tsx`, `frontend/src/hooks/useIdleTimeout.ts`); sin modelo Prisma	Claves `token` (JWT de sesión), `user` (`id`, `email`, `role`, `name`) y `umbral:last-activity` (marca de tiempo del cierre por inactividad, de 8 minutos). Vive solo en el navegador del profesional	Mantener la sesión iniciada y cerrarla por inactividad	Mismo criterio que la fila 16	El navegador del propio profesional. Cualquier script que corra en el origen del frontend podría leerlo (ADR 0003; la CSP de `frontend/vercel.json` reduce esa superficie)	Hasta el logout, la expiración del JWT (`JWT_EXPIRES_IN`, 8 h en `render.yaml`) o la revocación de la sesión

> **Nota sobre la fila 1 (versiones previas de este documento):** este RAT describía anteriormente roles `SUPERVISOR` / `COORDINATOR` / `ADMIN` y un modo de "acceso excepcional" con `AuditLog.overrideReason`, y una fila 4 de "Compartir con red de salud" (purpose `HEALTH_NETWORK`). Ninguno de los tres existe en el código: el schema colapsó a un único rol (enum `Role` del modelo `User` en `schema.prisma`), `AuditLog` solo tiene `detail` (no `overrideReason`, modelo `AuditLog`) y `ConsentPurpose` solo tiene `TREATMENT` / `TELEMEDICINE` (enum `ConsentPurpose`); `HEALTH_NETWORK` se eliminó por migración (`20260802100000_remove_health_network_consent`, ver issue #71). Corregido issue #65.

Transferencia internacional de datos

Toda la tabla de arriba asume implícitamente que los datos se procesan en Chile, pero eso ya no es así:

- La base de datos primaria (**todas** las filas 1-9: fichas, consultas, documentos, auditoría, historial) vive en **Supabase, hosteado en São Paulo, Brasil**.
- La copia de backup (fila 10) vive en **Backblaze B2, hosteado en Estados Unidos**, mitigado parcialmente porque llega cifrada con AES-256 antes de subir, así que Backblaze nunca tiene acceso al contenido en claro (a diferencia de Supabase, que sí lo tiene por necesidad operativa: no se puede consultar/actualizar una ficha clínica sin que la base la lea en claro).
- Backblaze B2 no solo guarda el backup: también aloja, en buckets privados y separados entre sí, los avatares, los archivos personales (`shared-files`) y los documentos adjuntos de la ficha (fila 5, cifrados en la aplicación antes de subir). Todos están en Estados Unidos, en la misma región (`us-west-004`): consta en `render.yaml` para avatares y el responsable del proyecto confirmó que los demás buckets usan la misma (issue #177). Los documentos adjuntos son datos de salud, por lo que les aplica la misma discusión de base habilitante que al backup.
- El email transaccional (fila 4) se envía vía **Resend, hosteado en Estados Unidos** ("Company's primary processing operations take place in the United States"), pero a diferencia de las filas 1-9, aquí el dato que transita es del **profesional que usa el sistema** (nombre, email), no del paciente. No es una transferencia

de datos de salud, así que la base habilitante que aplica no es el consentimiento informado del paciente sino la necesidad contractual de operar la cuenta del profesional.
- La sincronización opcional con Google Calendar (fila 11) envía a la **Google Calendar API (Google LLC, Estados Unidos)** únicamente contenido ya minimizado: iniciales + código no reversible + fecha/hora + link de vuelta a Umbral. Igual que con Resend, el dato que sale es del **terapeuta** operando su propia cuenta de Google, no una identificación directa del paciente, pero al tratarse de metadata de una sesión clínica (fecha/hora de atención), no está resuelto si la Ley 21.719 lo trata igual que el email transaccional de la fila 4 o si, por derivarse de un dato de salud, requiere la misma base habilitante que las filas 1-9. Pendiente de revisión legal, igual que el resto de esta sección.
- El registro de errores opcional (fila 20) envía a **Sentry** los eventos de error ya depurados (sin bodies, cookies ni headers; con emails y RUT redactados en el backend). La región de almacenamiento es Estados Unidos (Iowa): el DSN usa el host `ingest.us.sentry.io`, confirmado por el responsable del proyecto el 2026-10-08 (la documentación de Sentry fija la región al crear la organización: https://docs.sentry.io/organization/data-storage-location/). Su DPA firmado está en `docs/evidencia-compliance/sentry-dpa-firmado-2026-10-08.pdf`.
- El servidor de la aplicación (backend) se aloja en **Render, región Oregón (EE.UU. costa oeste)**, confirmado por el responsable del proyecto el 2026-10-08. Procesa todos los datos que pasan por la API; su DPA está en `docs/evidencia-compliance/render-dpa-2026-10-08.pdf`.
- El tráfico hacia la API pasa por **Cloudflare** antes de llegar a Render (`render.yaml`: `TRUSTED_PROXY_HOPS=3`, "Render detrás de Cloudflare"; ADR 0003). Cloudflare ve todo el tráfico de la API, incluidos los datos de pacientes en tránsito. No hay un DPA de Cloudflare en `docs/evidencia-compliance/` y la región de procesamiento no está documentada en este repositorio.
- El frontend (la aplicación web que carga el navegador) se sirve desde **Vercel** (`frontend/vercel.json`; dominio `umbral.groundzerodevs.com` según el ADR 0003). Vercel entrega los archivos estáticos y ve las IP de los visitantes, incluidos los pacientes que usan la agenda pública. No hay un DPA de Vercel en `docs/evidencia-compliance/` y su región no está documentada en este repositorio.
- Las tipografías se cargan desde **Google Fonts** (`@import` en `frontend/src/index.css`; la CSP de `frontend/vercel.json` permite `fonts.googleapis.com` y `fonts.gstatic.com`). Cada navegador que abre la aplicación, incluido el de un paciente en la agenda pública, hace peticiones a servidores de Google, que reciben su IP y su user agent.
- El cobro en línea por sesión (fila 13) se procesa vía **Flow, cuya infraestructura de checkout corre en AWS us-east-2 (Ohio, Estados Unidos)**, verificado por DNS/rangos IP de AWS, ver evidencia más abajo (issue #118), pese a que la entidad contratante (Flow Pagos Chile SpA) está domiciliada en Chile. Igual que con Resend/Google, el dato que transita es del **paciente** (nombre, email, monto) pero no es dato clínico, así que la base habilitante en discusión no es el consentimiento informado de tratamiento sino la necesidad contractual de operar el cobro de la sesión.

Esto constituye una transferencia internacional de datos de salud, que la Ley 21.719 regula explícitamente (requiere alguna base habilitante: nivel de protección adecuado del país destino, cláusulas contractuales con el proveedor, consentimiento explícito informado del paciente sobre dónde se almacenan sus datos, u otra excepción legal). **Esto no está resuelto ni evaluado legalmente**: determinar si la configuración actual (Supabase Brasil + Backblaze EE.UU.) cumple la Ley 21.719, y qué hace falta si no cumple (cláusulas contractuales, ajustar el texto del consentimiento informado, u otra medida), requiere revisión de alguien con conocimiento legal real, no es una decisión de ingeniería. Hasta que se resuelva, este punto queda documentado aquí como riesgo abierto y conocido, no como algo ya evaluado y aceptado.

Evidencia recopilada hasta ahora (issue #55), guardada en `docs/evidencia-compliance/` (snapshots en PDF, con fecha, de páginas públicas que los proveedores pueden actualizar):

- **Supabase**: `supabase-dpa-2026-08-03.pdf`: el DPA se incorpora automáticamente al aceptar los Términos de Servicio (cláusula 12.2: "*acceptance of the Agreement shall have the same effect as signing the SCCs*"), sin firma separada. Confirmado por fuente oficial.
- **Render**: `render-dpa-2026-10-08.pdf`: snapshot del DPA de Render (https://render.com/dpa) guardado el 2026-10-08. Falta confirmar si se incorpora automáticamente al aceptar los Términos o requiere aceptación aparte, y si cubre una transferencia desde Chile (el texto cita GDPR, Data Privacy Framework y SCC de la UE).
- **Sentry**: `sentry-dpa-firmado-2026-10-08.pdf`: DPA aceptado y firmado electrónicamente desde la cuenta del proyecto el 2026-10-08. Misma salvedad sobre la transferencia desde Chile.
- **Backblaze**: `backblaze-dpa-eea-eu-2026-08-03.pdf` + `backblaze-tos-2026-08-03.pdf`: mismo mecanismo de incorporación automática, pero el DPA público encontrado está textualmente acotado a *"when GDPR applies"* (UE/EEA). No confirma por sí solo que aplique a una transferencia desde Chile. Pendiente: respuesta de `privacy@backblaze.com` sobre si combinan su DPA/SCCs con las Cláusulas Contractuales Modelo (CCM) que el Ministerio de Economía de Chile aprobó en diciembre 2025 (Resolución RAEX202503748) para transferencias bajo la Ley 21.719 -- ojo que la validez de esa aprobación ministerial también está en debate legal (¿le correspondía a la futura Agencia de Protección de Datos Personales, no al Ministerio?).
- **Resend**: `resend-dpa-2026-08-04.pdf`: mismo mecanismo de incorporación automática del DPA al aceptar los Términos de Servicio (`resend.com/legal/dpa`). Procesamiento primario en Estados Unidos; lista de subprocesadores en `resend.com/legal/subprocessors`. El alcance del DPA es amplio (EU SCCs/GDPR, UK SCCs, Suiza FADP, CCPA) pero, igual que con Backblaze, no menciona Chile ni la Ley 21.719 explícitamente.
- **Google** (issue #117): `google-dpa-2026-09-21.pdf`: Cloud Data Processing Addendum oficial (versión es-419, descargado directo de `cloud.google.com/terms/data-processing-addendum`), que cubre Google Workspace/Cloud Identity según su Appendix 4 (Specific Products). **Ojo**: el DPA aplica a cuentas contratadas bajo un Acuerdo de Google Workspace/Cloud Identity; no está confirmado que rija sobre una cuenta de Google **personal/gratuita**, que es la que el terapeuta conecta hoy vía OAuth (`calendar.events`, fila 11). Sigue pendiente de revisión legal si el DPA aplica igual, o si una cuenta personal se rige solo por los Términos de Servicio generales de Google (sin DPA formal), y cuál base habilitante corresponde en ese caso.
- **Flow** (issue #118): `flow-privacidad-2026-09-21.pdf` (Política de Privacidad oficial, `flow.cl/docs/privacidad/`) + `flow-terminos-condiciones-2026-09-21.html` (snapshot íntegro de `web.flow.cl/es-cl/legal/`; Flow no publica sus Términos y Condiciones como PDF descargable, a diferencia de Supabase/Backblaze/Resend/Google, así que se capturó la página completa en vez de un PDF). Los T&C confirman que las entidades que operan en Chile (**Flow Pagos Chile SpA**, RUT 76.644.017-7, y **Flow Subadquirente**) están constituidas conforme a la legislación chilena, domiciliadas en Santiago, y que "el tratamiento de datos personales efectuado por las Entidades Flow domiciliadas en Chile se regirá por la normativa chilena vigente en materia de protección de datos". Pero **domicilio legal no es lo mismo que ubicación física del procesamiento**, y verificado por separado (2026-09-21), resulta ser lo contrario: los hosts que efectivamente usa la integración (`sandbox.flow.cl/api`, el `DEFAULT_API_BASE_URL` de `flow-gateway.client.ts`, y su equivalente de producción `www.flow.cl`) resuelven a IPs de **AWS EC2 en la región `us-east-2` (Ohio, Estados Unidos)**, confirmado cruzando la resolución DNS contra `ip-ranges.amazonaws.com` (rangos IP oficiales publicados por AWS), y corroborado por la cookie `AWSALB` / `AWSALBCORS` que ambos hosts devuelven (firma de un Application Load Balancer de AWS). Esto es evidencia técnica directa, no una declaración oficial de Flow, pero es reproducible:

cualquiera puede repetir la resolución DNS y el cruce contra los rangos de AWS. **Conclusión**: la fila 13 **sí** constituye una transferencia internacional de datos (mismo tratamiento que Supabase/Backblaze/Resend), pese a que la entidad contratante esté domiciliada en Chile.

Cifrado y medidas técnicas

Hechos verificados contra el código el 2026-10-13. No es una evaluación de suficiencia de las medidas.

Dato	Dónde vive	Protección en reposo aplicada por la aplicación
Documentos de pacientes (incluye el PDF del informe de alta y las autorizaciones de entrega)	Bucket B2 `B2_PATIENT_DOCUMENTS_*`; la base guarda solo `PatientDocument.storagePath`	AES-256-GCM con `DOCUMENT_ENCRYPTION_KEY`, formato binario `0x02` con AAD (cabecera más etiqueta `documents`)
Refresh token de Google	`GoogleCalendarConnection.refreshTokenEncrypted`	AES-256-GCM con `GOOGLE_TOKEN_ENCRYPTION_KEY`, etiqueta `google`
Credenciales de Flow del terapeuta	`PaymentAccount.credentialEncrypted`	AES-256-GCM con `PAYMENT_CREDENTIALS_ENCRYPTION_KEY`, etiqueta `payment`
Secreto TOTP	`User.mfaSecret`	AES-256-GCM con `MFA_SECRET_ENCRYPTION_KEY`, texto `enc:v3:<keyId>:<base64>` con AAD, etiqueta `mfa`
Contraseña y códigos de recuperación de MFA	`User.passwordHash`, `MfaRecoveryCode.codeHash`	Solo se guarda el hash Argon2; no hay forma de recuperar el valor original
Respaldo de la base	Bucket B2 del respaldo	`openssl enc -aes-256-cbc -pbkdf2` con la frase `BACKUP_PASSPHRASE` (fila 10)
Datos de la ficha, notas de consulta, historiales (`PatientHistory`, `ConsultationHistory`), textos del informe de alta, avatares y archivos personales	Base de datos y buckets B2	Sin cifrado a nivel de aplicación (ADR 0004). El cifrado en reposo del disco de Supabase no está verificado

- **Llavero versionado (ADR 0005).** En cada clave de la tabla, la variable de entorno original es la clave id 0; `<NOMBRE>_KEYRING` agrega claves con ids de 1 a 255 y `<NOMBRE>_ACTIVE_KEY_ID` elige con cuál se cifra. El código lee los formatos anteriores (sin cabecera, `0x01`, `enc:v1`, `enc:v2`) y escribe solo `0x02` y `enc:v3`. El re-cifrado y la verificación de retiro de una clave se hacen con `npm run crypto:reencrypt` (`backend/scripts/reencrypt-keys.ts`); el procedimiento está en `docs/rotacion-y-respaldo-de-claves.md`.
- **Autenticación y sesión.** MFA TOTP con anti-reutilización de código (`lastUsedStep`), sesiones revocables con `jti` (fila 16), JWT de 8 horas (`JWT_EXPIRES_IN`) y límites de intentos por ruta (fila 27).
- **Aislamiento entre terapeutas.** Lo hacen los filtros por `therapistId` en los servicios. Las migraciones tienen 27 sentencias `ENABLE ROW LEVEL SECURITY` y ninguna `CREATE POLICY`; la aplicación se conecta con un rol con `BYPASSRLS` (ADR 0004). La migración que crea `TreatmentDischarge` (`20261011130000_add_treatment_discharge`) no incluye `ENABLE ROW LEVEL SECURITY`, a diferencia de las demás tablas de la aplicación.

- **Bitácora.** `AuditLog` es append-only por trigger y por permisos del rol de ejecución (fila 7; `docs/incident-log.md`).
- **Cabeceras HTTP.** `helmet()` en el backend y una Content-Security-Policy, `X-Content-Type-Options` y `Referrer-Policy` en `frontend/vercel.json`.

Criterio del gate de consentimiento (issue #176)

El consentimiento informado (`PatientConsent`, purposes `TREATMENT` / `TELEMEDICINE`) se exige **antes de registrar datos clínicos**, no antes de crear la ficha administrativa del paciente. Criterio: la Ley 20.584 exige el consentimiento previo al inicio del tratamiento, y `recordConsent` necesita un `Patient` existente, por lo que exigirlo antes del alta sería circular.

- **Dónde se aplica:** `ConsultationsService.create()` y `correct()` rechazan con 403 si no hay consentimiento vigente; el chequeo corre dentro de la misma transacción que la escritura. Son los únicos endpoints de escritura sobre `Consultation` (`POST /consultations` y `PATCH /consultations/:id/correct`).
- **Qué no se gatea:** el alta y la edición de datos de identidad/contacto del `Patient`, y su historial de cambios (`PatientHistory`). No contienen notas clínicas.
- **Reserva pública:** `createFromPublicBooking()` crea una `Consultation` sin consentimiento previo. Es un agendamiento, no un inicio de tratamiento: nace con texto genérico (`Reserva pública en línea` / `Pendiente de definir por el terapeuta`) y ningún dato clínico. La `Consultation` es la entidad de la que dependen disponibilidad, Google Calendar, cobro y agenda, por lo que no se separó del agendamiento. Los datos clínicos solo pueden ingresar mediante `correct()`, que exige el consentimiento.

Esto es orientación técnica, no validación legal.

Pendientes conocidos

- **Transferencia internacional de datos**: ver sección de arriba. Es el pendiente más importante de este documento hoy. Incluye la sincronización opcional con Google Calendar (fila 11): la evidencia del DPA de Google ya se recopiló (issue #117, `google-dpa-2026-09-21.pdf`), pero sigue sin resolverse si aplica a una cuenta personal (no Workspace) del terapeuta, y si corresponde la base habilitante de dato de salud o la de cuenta de profesional. También incluye el cobro en línea por sesión (fila 13): ya se confirmó que Flow procesa en AWS us-east-2, Estados Unidos (issue #118); falta la misma revisión legal de base habilitante que el resto de esta sección.
- **Cloudflare, Vercel y Google Fonts**: figuran en la sección de transferencia internacional como parte de la ruta del tráfico, pero no tienen evidencia recopilada (DPA, región) ni revisión legal.
- **Firma electrónica avanzada** (filas 2 y 6, a futuro): la firma de cada consulta/corrección y el sello de tiempo en los PDF exportados dependen de elegir un proveedor acreditado por la Ley 19.799; ver issues #24, #25, #26 (T5.1, T5.2, T5.3).
- **Consentimiento específico para el email de link de pago** (fila 13): a diferencia de las demás filas, el envío automático del link de pago al email del paciente (`sendPaymentLinkEmail`) no está gateado hoy por ningún `ConsentPurpose` propio: la implementación (`sdd/online-payment-integration`) deliberadamente no inventó un member nuevo del enum sin definición legal confirmada. Si legal determina que corresponde una finalidad separada de `TREATMENT`, agregar el member y el gate es un cambio aditivo que no altera ninguna otra decisión de este módulo.

- **Consentimiento para pacientes autocreados vía auto-agenda pública** (fila 14): a diferencia de un paciente creado por un terapeuta autenticado, un paciente autocreado desde el formulario público de reserva no pasa hoy por ninguna captura de consentimiento informado (`PatientConsent` , purpose `TREATMENT`). No está resuelto si corresponde capturar consentimiento en ese mismo formulario público, si debe entenderse otorgado de otra forma, o si queda como una regularización manual pendiente del terapeuta; requiere revisión de alguien con conocimiento legal real, mismo criterio que el resto de esta sección.
- **Informe de alta** (filas 23 a 25, ADR 0006): el diseño (firma simple más hash SHA-256) es una decisión de producto, no una exigencia legal. Siguen sin resolver: si la autorización cargada para entregar el informe a un tercero debe cumplir la formalidad del art. 13 letra b) de la Ley 20.584 (poder simple ante notario), que hoy el sistema no exige; confirmar el art. 13 contra el texto consolidado de BCN (se leyó con SUSESO y el Diario Oficial de la Ley 21.668) y la vigencia del código de ética del Colegio de Psicólogos (solo se halló la versión de 1996); si la firma simple basta para colegios, tribunales y otros prestadores; el cifrado a nivel de columna de los textos del informe; la auditoría de lectura de la lista de entregas; y la validación de que el documento de un tribunal sea un oficio. Hay un menor real en producción sin representante cargado; hay que regularizarlo antes del 2026-12-01 (ADR 0007).
- **Pacientes menores de edad y representante legal** (filas 21 y 22, ADR 0007): el diseño (autorización del representante más asentimiento del paciente por tramos de edad) es una recomendación conservadora de producto, no una exigencia legal verificada. Siguen sin resolver: la revisión legal de la confidencialidad del adolescente de 14 a 17 años frente al derecho de los padres; el estado del Boletín 18.623-07 (postergación de la Ley 21.719); la vigencia del código de ética del Colegio de Psicólogos (el art. 13 de la Ley 20.584 ya se leyó, ver el ADR 0006); y el hecho de que un representante cargado desde la agenda pública (fila 14) queda con `canConsent` activo sin que el sistema capture su consentimiento en ese formulario. Hasta el 2026-12-01 el sistema aún acepta el consentimiento legado de un menor (otorgado por él mismo); desde esa fecha lo exige otorgado por un representante.

Mantenimiento de este documento

Actualizar esta tabla cuando:

- Se agregue un modelo o campo nuevo en `schema.prisma` que trate datos personales de pacientes o usuarios.
- Se agregue una nueva finalidad de consentimiento (`ConsentPurpose`).
- Se agregue o cambie un procesador externo (por ejemplo, un servicio de monitoreo de errores) o un servicio de infraestructura por el que pase tráfico (hosting, CDN, fuentes).
- Se revise el documento: actualizar la fecha de "Última revisión" al inicio, aunque no haya cambios.
- Cambie algún plazo de retención o se resuelva alguno de los pendientes listados arriba.